

Week 5

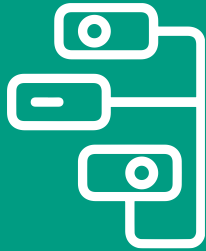
Backups & Security



Agenda



Wat is storage?



**Storage architectuur
ontwerpen**



**ICT
Security**

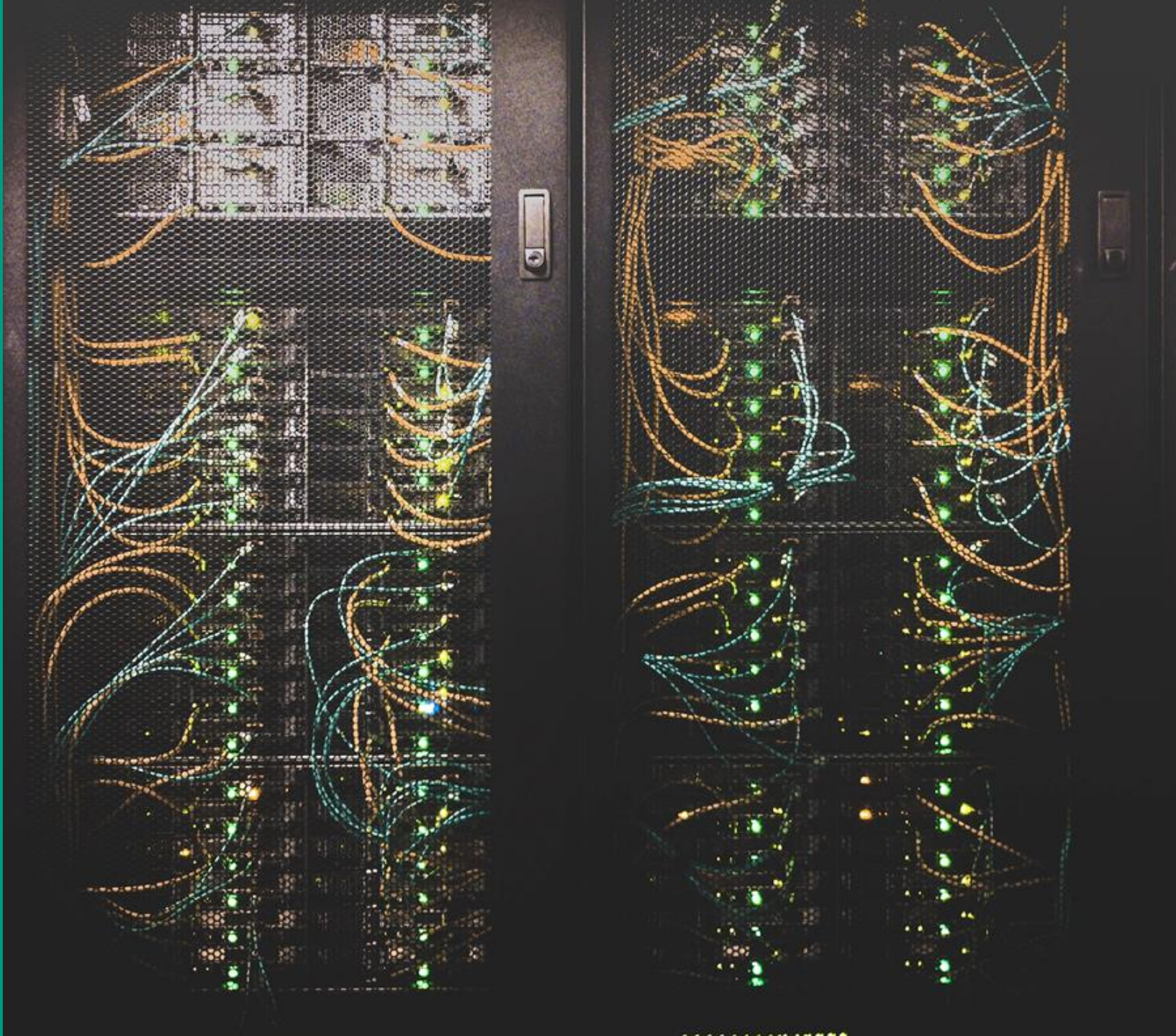


ISO 27001/ 27002



**NIST Cybersecurity
Framework**

**Wat is storage
en welke
typen zijn er?**



Wat is storage?

- Een **apparaat** of **medium** waar data in opgeslagen kan worden

Verschillende media:

- Harddisk (roterende schijven)
- SSD of Flash (op chip; geen bewegende onderdelen)
- Cdrom of magneetband

Vormen van storage:

- Opslag in eigen datacenter (DAS, NAS, SAN)
- Cloudopslag (cloud storage)
- Hybride opslag: zowel lokale en cloudopslag (multi storage)

Het soort dataopslag dat nodig is hangt af van veel factoren.
Performance, beveiliging en de **hoeveelheid** ervan spelen een rol.



Storage hiërarchie



CPU Klocksnelheid max +/- 4 GHz

Registers en L1, L2, L3 Cache: ~ MB
Supersnel. Instructie duurt **4 ns**



Main memory: ~GB
Erg snel. Toegangstijd **nanoseconden**



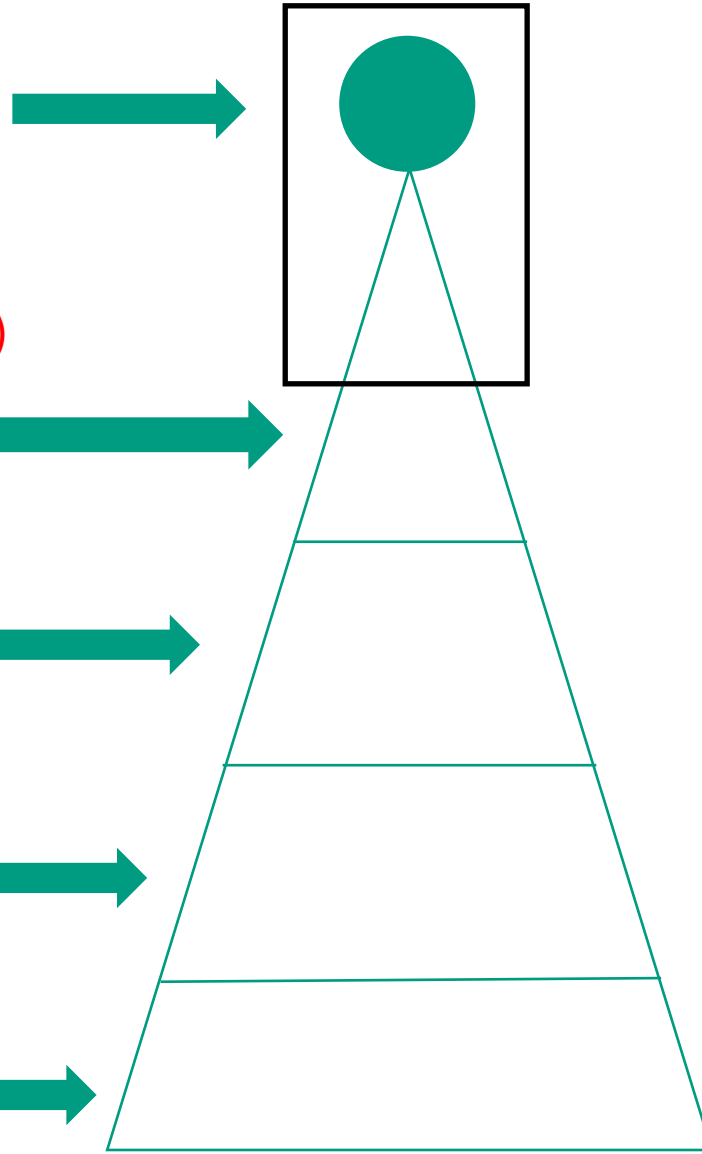
SSD of Flash: ~GB
Snel. Toegangstijd **microseconden**



HDD: ~TB
Minder snel. Toegangstijd **milliseconden**



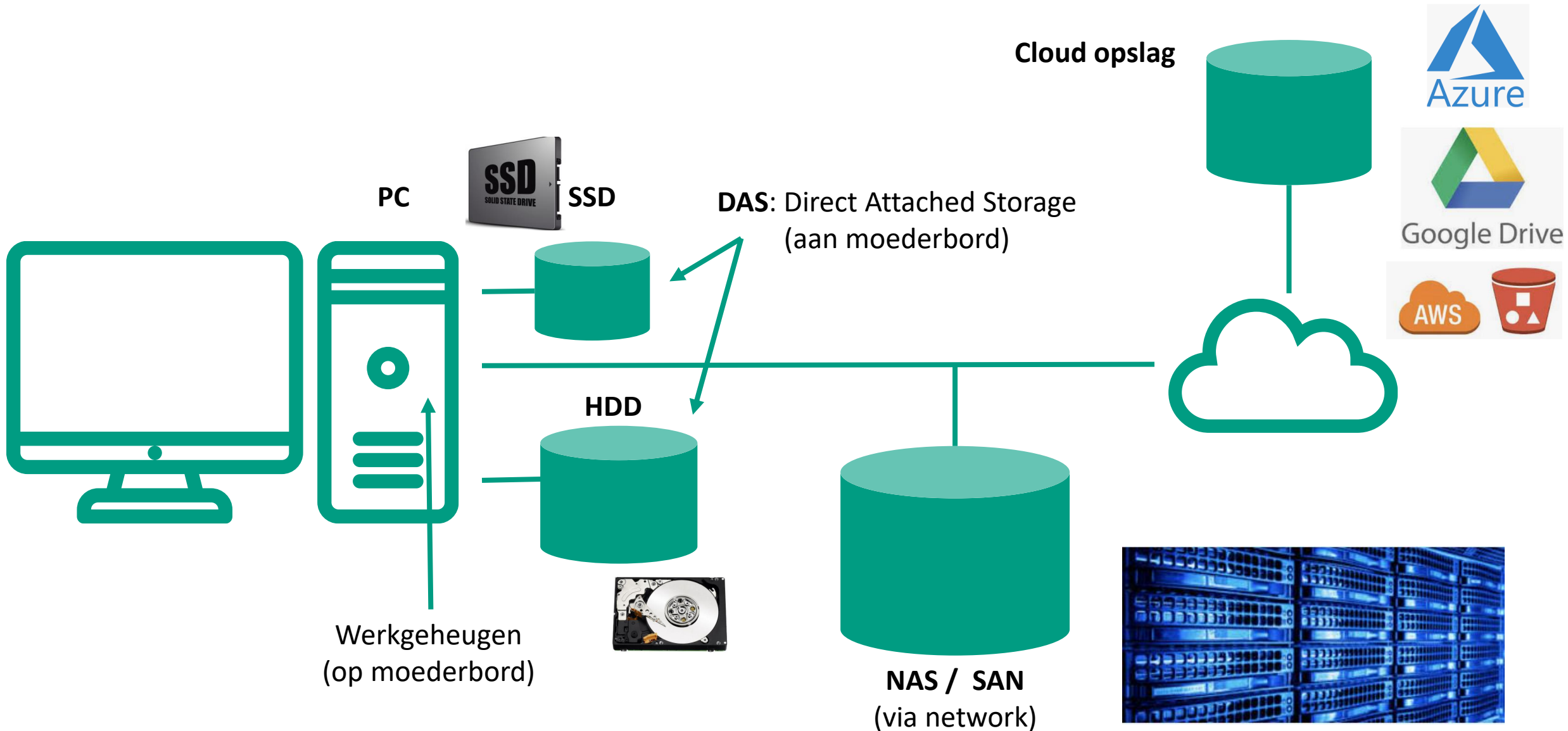
Netwerk storage: ~TB
Minder snel. Toegangstijd **milliseconden**



Deze les gaat over
Persistent storage!

Secundaire
storage
(persistent)

Storage hiërarchie: waar zit wat?



Soorten storage

- **HDD (Hard Disk Drive):** Veel gebruikt voor personal computers, servers en storagesystemen. Roterende harde schijf (toerental tot 15000 per minuut).
- **SSD (Solid State Drive):** Slaan data op in niet-vluchtige flash-geheugenchips. **Geen** roterende delen.
- **Flash-geheugenkaarten:** Wordt gebruikt in digitale camera's en mobiele apparaten, zoals smartphones, tablets, geluidsrecorders en mediaspelers. USB-geheugensticks zijn ook een vorm van solid-state opslag.
- **CD-ROM (Optische gegevensopslag):** Wordt gebruikt voor bijvoorbeeld computerspellen en opslag films.
- **Magneetband of tapes:** Wordt gebruikt voor back-ups.



Storage omvang

Een enkele binaire waarde (1 of 0) is een bit, acht bits vormen samen één byte

- 8 bits (b) = 1 byte (B)
- 1 kilobyte (KB) = 1024 bytes
- 1 megabyte (MB) = 1.024 KB
- 1 Gigabyte (GB) = 1.024 MB
- 1 Terabyte (TB) = 1.024 GB
- 1 Petabyte (PB) = 1.024 TB
- 1 Exabyte (EB) = 1.024 PB

Opslag **PC** 100 à 1000 GB

Opslag op **storagemachines**

als SAN:

vaak 100 TB – 1 PB.

Petabyte SAN



Storage Management

Belangrijke taken van de Storage Administrator:

- Voldoende storage met de juiste performance
- Alleen bevoegden krijgen toegang tot bepaalde data
- Encryptie (indien nodig)
- Back-ups
- Continue beschikbaarheid
- Archivering en later opruimen als data niet meer nodig is.



Wat is belangrijk
voor ontwerpen
storage architectuur?



Uitgangspunten van storagearchitectuur

Functionaliteit:

- Vereiste performance?
- Vereiste beschikbaarheid (24/7)?
- Omvang (GB, TB of ..)?

Calamiteit

Belangrijkste parameters voor het opstellen van bedrijfscontinuïteits- en noodherstelplannen zijn:

De **RTO** (Recovery Time Objective) en **RPO** (Recovery Point Objective)

Beide helpen met:

- Het herstelproces
- Het bepalen van de hersteltijdlimieten
- De frequentie van back-ups
- De herstelprocedures

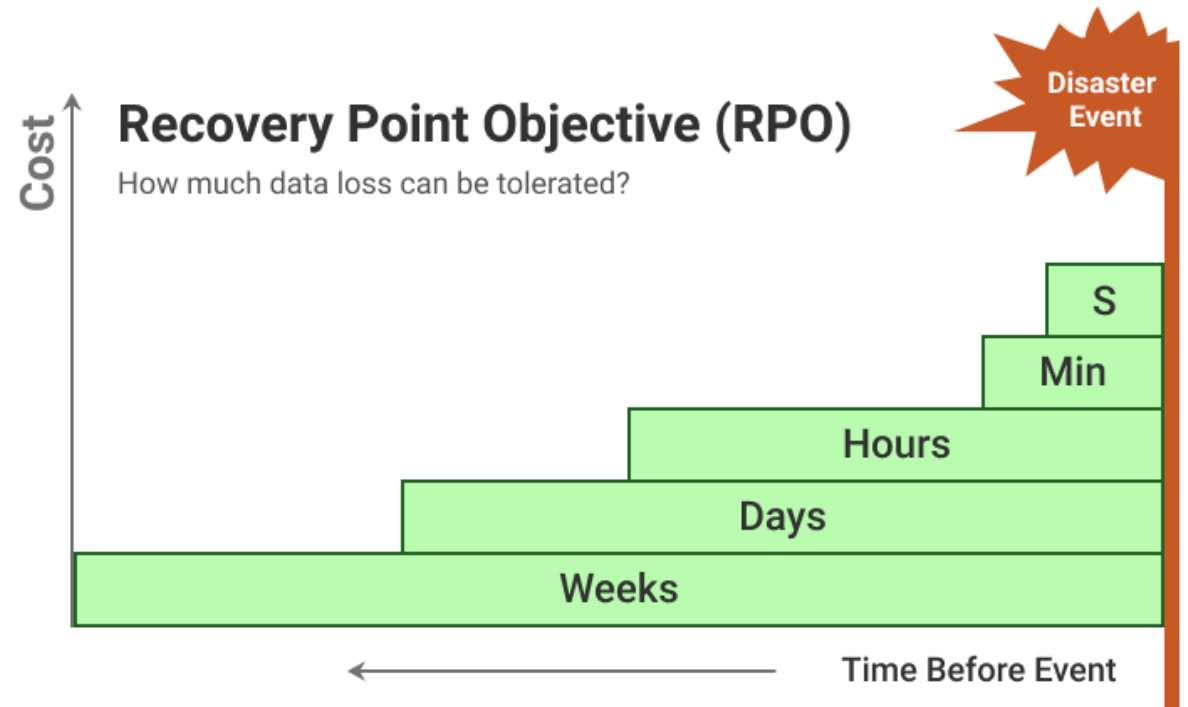


RPO

- **RPO**, of 'Recovery Point Objective' = Maatstaf voor de maximaal aanvaardbare hoeveelheid gegevens die een bedrijf zich kan veroorloven te verliezen tijdens een calamiteit.
- RPO is nuttig om te bepalen hoe vaak gegevensback-ups moeten worden uitgevoerd.

Factoren voor het bepalen van uw RPO:

- De maximaal aanvaardbare hoeveelheid gegevensverlies die de organisatie kan verdragen.
- De kosten van verloren gegevens.
- Beschikbaar budget en middelen.

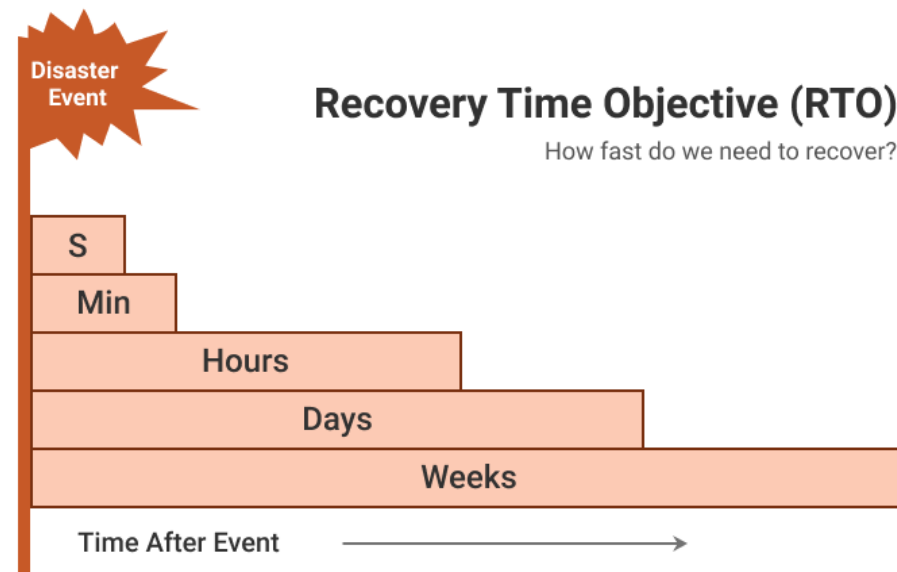


RTO

RTO (Recovery Time Objective) = Maatstaf die aangeeft hoe lang het duurt voordat de IT-infrastructuur en -diensten na een ramp hersteld zijn.

Om RTO te berekenen, overweeg deze factoren:

- Tijd die het kost de data terug te zetten (*Terabytes kopiëren duurt lang*).
- Belang & prioriteit van individuele systemen.
- Stappen die nodig zijn om te herstellen van een ramp (inclusief individuele componenten en processen).
- Beschikbaar budget en middelen



Situatie 1: Thuis computer

Waar sla je data op (b.v. foto's)?

1) Lokale schijf (of SSD) van de computer.

Eigenschap:

- Alleen toegang via deze PC
Als schijf crashed = Alles weg.

Oplossing:

- Maak regelmatig back-ups. Sla die op een andere schijf.
Hoe vaak: ligt aan je RPO. (mogen de laatst bewaarde foto's kwijt zijn?)

Beschermen tegen kans op uitval schijf: RAID



Situatie 1: Thuis computer

2) Op een schijf of storageapparaat in het netwerk (NAS, Network Attached Storage)

Eigenschap:

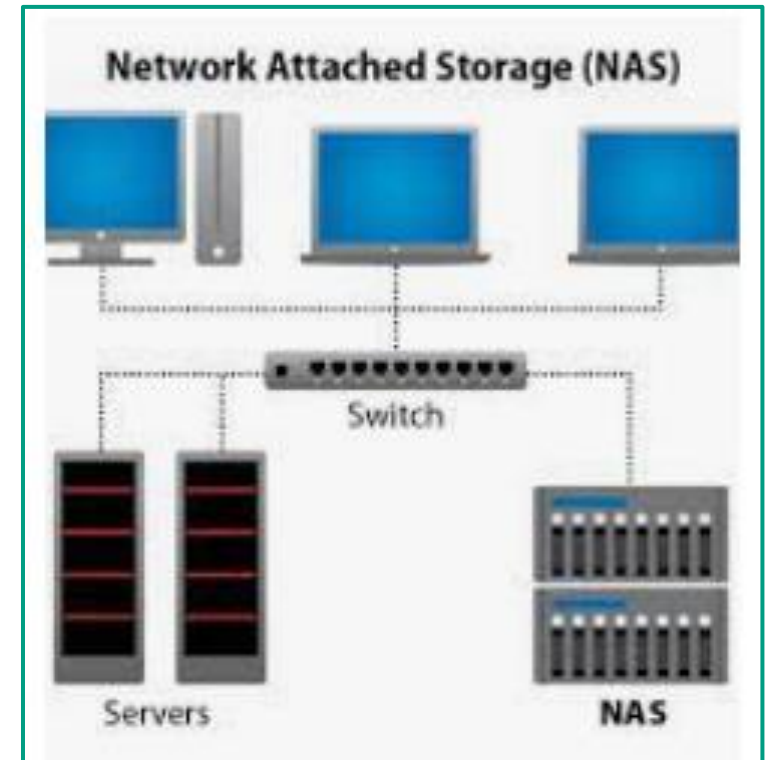
- Vanaf meerdere apparaten toegang mogelijk
Als NAS crashed = alles weg

Oplossing:

- Maak regelmatig back-ups. Sla die op een ander apparaat op of in de cloud (dropbox).
Hoe vaak: ligt aan je RPO. (mogen de laatst bewaarde foto's kwijt zijn?)

Beschermen tegen kans op uitval schijf: RAID

3) Wat is thuis de geschatte RTO als een schijf stuk gaat?



Opdracht: bepaal storagearchitectuur thuis

Requirements:

- Stel thuis zijn 4 gebruikers met eigen laptops.
- Elke gebruiker heeft foto's en belangrijke bestanden (elke dag worden nieuwe toegevoegd) op de eigen laptop. Backups worden gemaakt naar de NAS (ook thuis).
- Per dag wordt er 0,25 GB aan foto's of nieuwe bestanden gecreëerd per gebruiker.
- Men wil nooit meer dan 1 week aan data (foto's en bestanden) verliezen.
- Men wil de data van de komende 5 jaar kunnen opslaan.

Ontwerp de storagearchitectuur en geef aan:

- Een schematische tekening van het ontwerp
 - Hoeveel opslag elke PC moet hebben
 - Hoe groot de NAS moet zijn.
 - Hoe vaak er een backup gemaakt moet worden vanaf de PC naar de NAS.
-
- Zou je adviseren ook nog een extra backup van de NAS naar bv de cloud te maken? Zo ja waarom?



Wat is een RAID systeem?

- **RAID** (Redundant Array of Disks) → Harde schijven zo geconfigureerd dat deze samenwerken.
- **'Array of disks'** = Combinatie van verschillende schijven. Iedere array wordt door de PC gezien als een enkele schijf.
 - In werkelijkheid bestaat een array uit diverse harde schijven.
Doel = De **snelheid vergroten of de kans op dataverlies (fout correctie) te verkleinen** of beide.
- RAID configuraties hebben allemaal voor- en nadelen. Keuze hangt dus af van de doelen die je wilt bereiken. Dus ligt het belang bij: snelheid, opslagruimte, foutcorrectie of kosten?
- Deze verschillende RAID configuraties worden aangeduid met diverse nummers. Bijvoorbeeld: RAID 0, RAID 1, RAID 5 etc.



Belangrijke vraag:

Als je RAID toepast → Hoef je dan geen back-ups meer te maken?

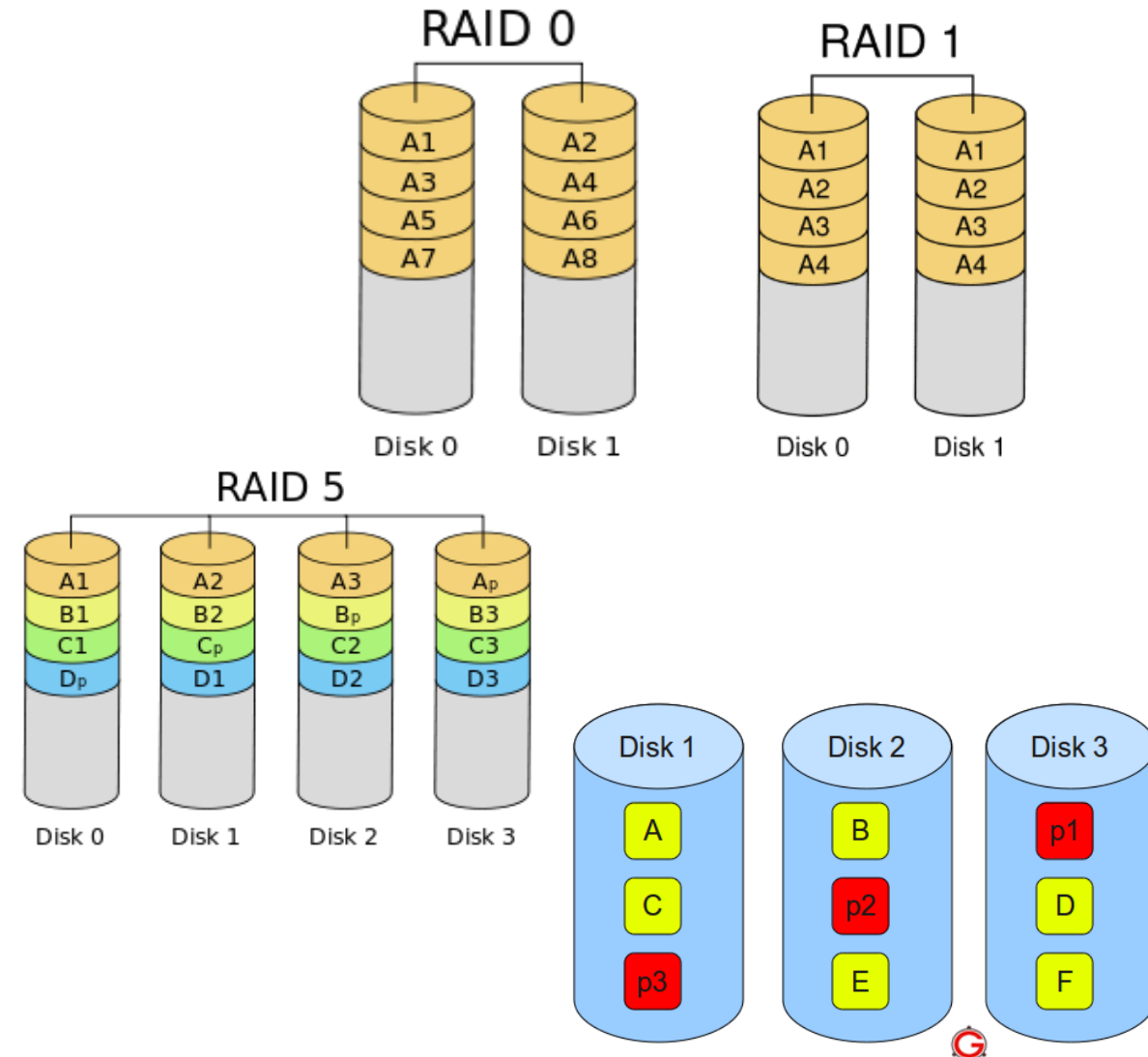
Belangrijke vraag:

Als je RAID toepast → Beschermst dat ook tegen gebruikersfouten (bv foto per ongeluk verwijderd)?

Wat is een RAID systeem?

RAID Level Summary

Category		Description	I/O Request Rate (Read/Write)	Data Transfer Rate (Read/Write)	Typical Application
Striping	0	Non-redundant	Large strings: Excellent	Small strips: Excellent	Applications requiring high performance for non-critical data
Mirroring	1	Mirrored	Good/fair	Fair/fair	System drives; critical files
Parallel access	2	Redundant via Hamming code	Poor	Excellent	
	3	Bit-interleaved parity	Poor	Excellent	Large I/O request size applications such as imaging, CAD
Independent access	4	Block-interleaved parity	Excellent/fair	Fair/poor	
	5	Block-interleaved distributed parity	Excellent/fair	Fair/poor	Applications requiring extremely high availability
	6	Block-interleaved dual distributed parity	Excellent/poor	Fair/poor	



RAID 5 – Blocks Striped. Distributed Parity.

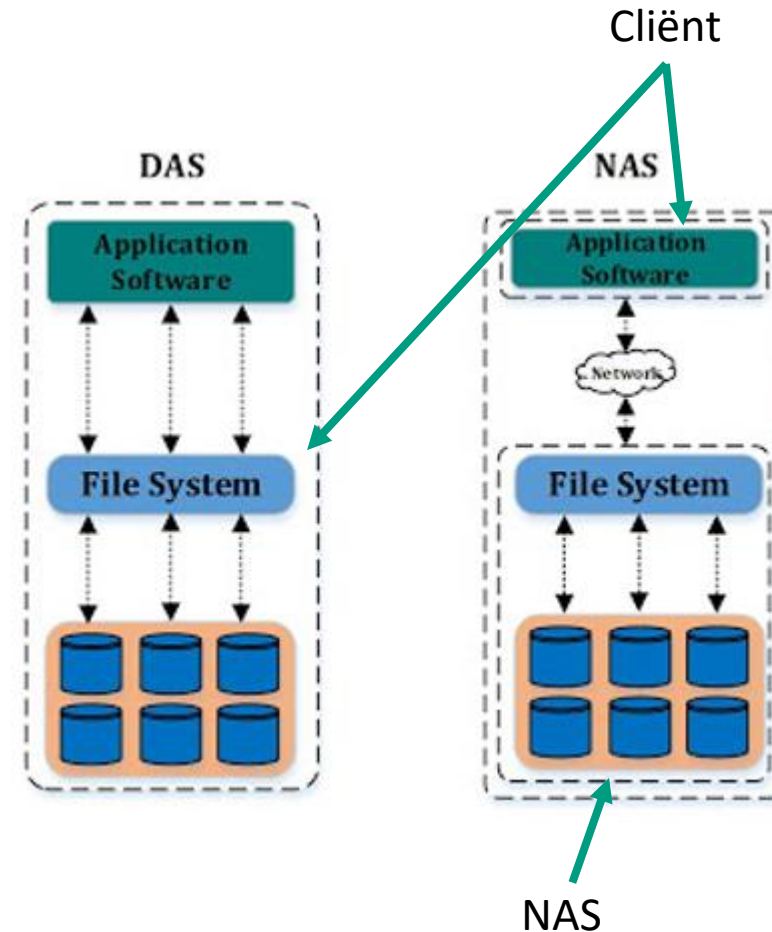
DAS en NAS

1. DAS Direct Attached Storage

- Filesystem gemaakt door host (bv Windows NTFS)
- Direct gekoppeld aan machine

2. NAS Network Attached Storage

- Filesystem gemaakt door NAS (bv Linux EXT4)
- Gekoppeld aan het netwerk
- Fileshare (als dropbox)
- Connection: filesharing protocol (cifs of nfs)



Verschillende type NAS systemen

Enterprise



Midmarket



Consumer



Verschillende type NAS systemen

Enterprise-Level NAS	Midmarket NAS	Consumer-Level NAS
Serves more than 1000 clients	Connected clients are lesser as compared to enterprise-level NAS	Most brands support connectivity of up to 20 clients
High storage capacity - Up to petabytes	Most midmarket NAS servers support 20-64 TB storage capacity	Supports up to 20 TB of storage capacity
RAID and Virtualization capabilities	RAID and Virtualization capabilities	RAID is not supported
High availability with clustering	Clustering is usually not supported	Clustering is not supported
Typically used for data backup and sharing files	Used for data backup, sharing files	Used for storing and backing up data, sharing files, streaming media
Used for hosting applications that support email systems, accounting database, payroll, video recording and editing, data logging, etc.	Used for hosting applications that support email systems, accounting database, payroll, video recording and editing, data logging, etc.	Most brands don't offer cloud backup
Cloud backup available	Cloud backup available	Remote access to data
Remote access to data	Remote access to data	



Situatie 2: bedrijf (bijv. Saxion)

Waar slaat Saxion alle data op?

1) **Locale schijf (of SSD) van de computer.**

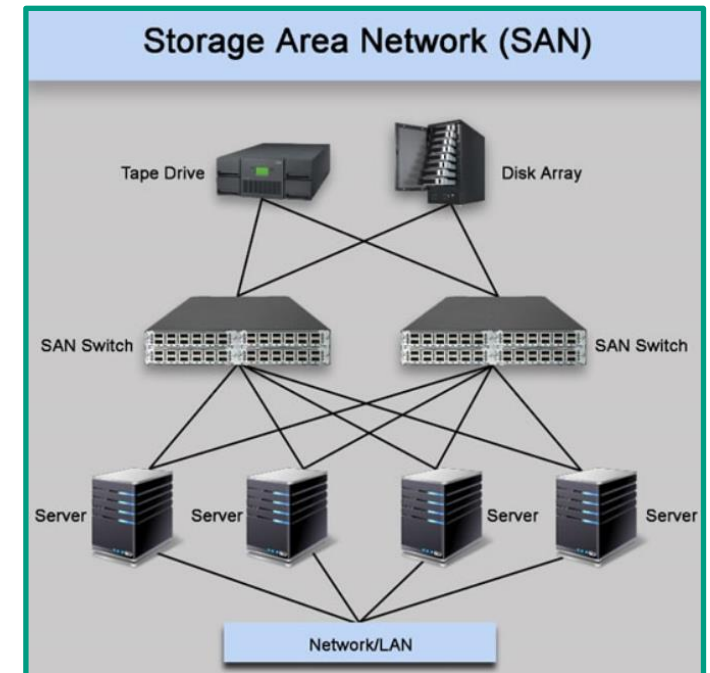
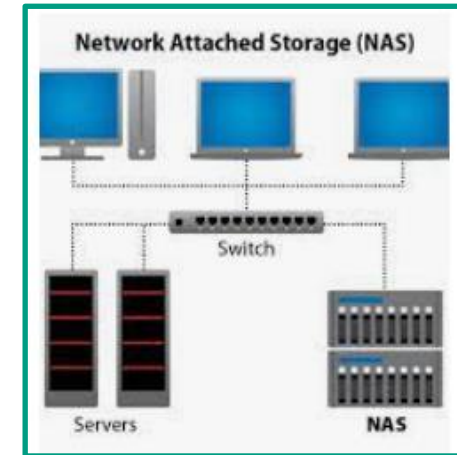
- Nee; te kwetsbaar, te klein

2) **Op een schijf of storageapparaat in het netwerk (NAS, Network Attached Storage)**

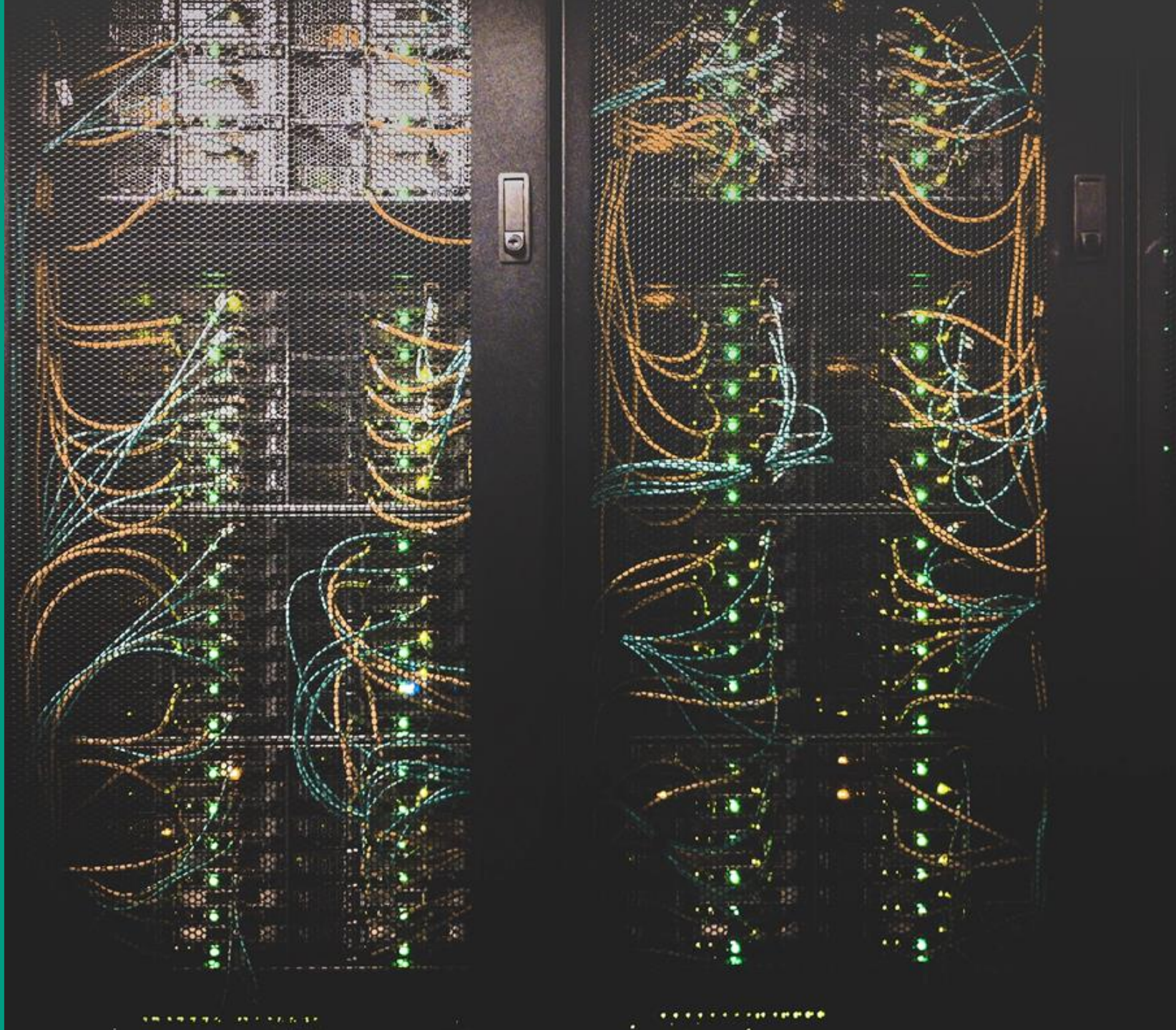
Als fileshare mogelijk geschikt (bv voor docenten).

3) **Op een SAN (Storage Area Network):** apart storage netwerk waarin Single Points of Failures (SPOFs) voorkomen worden
Gebruikt voor opslag virtuele machines (goede performance nodig)

Zijn hier back-ups
nodig en hoe vaak?



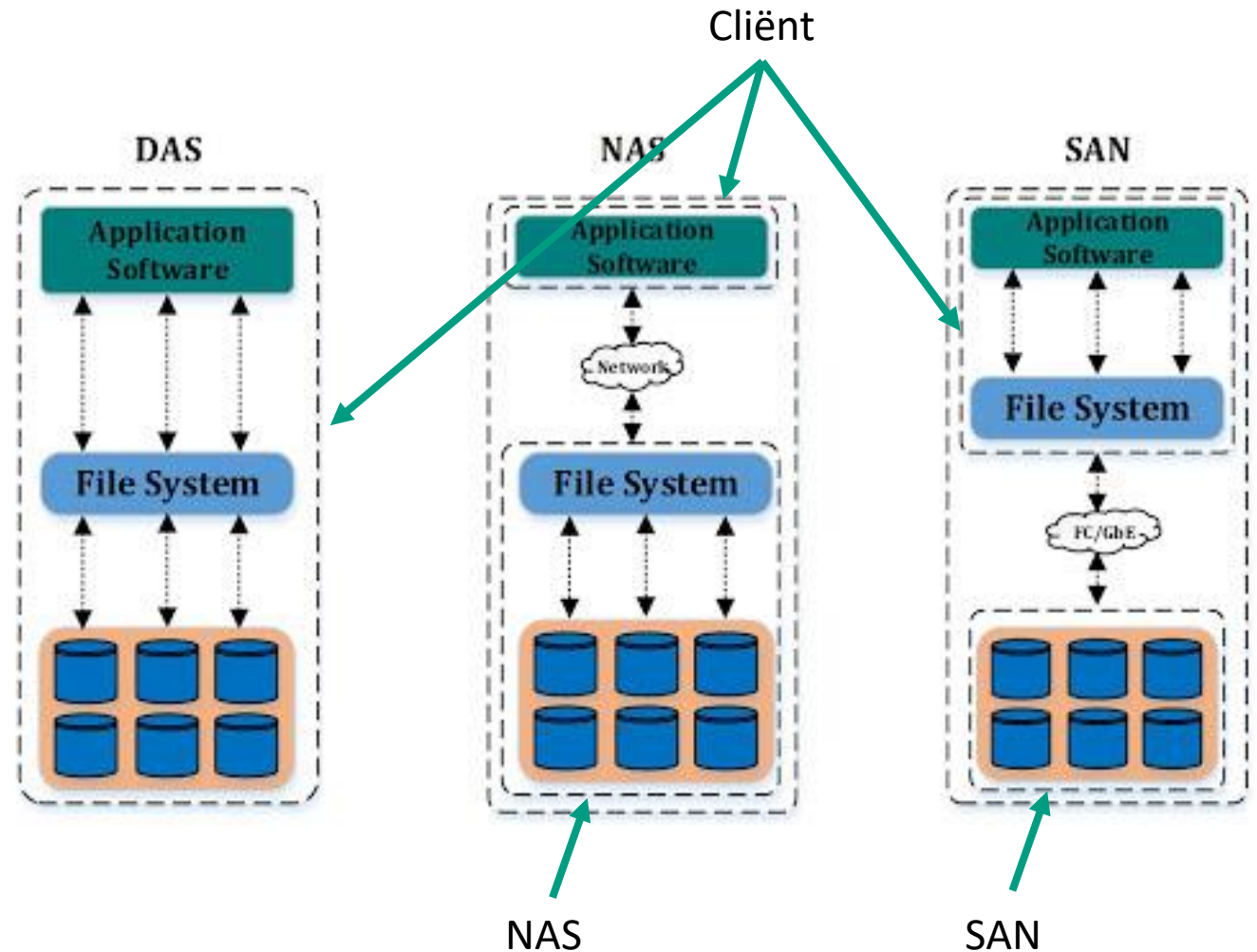
SAN versus NAS

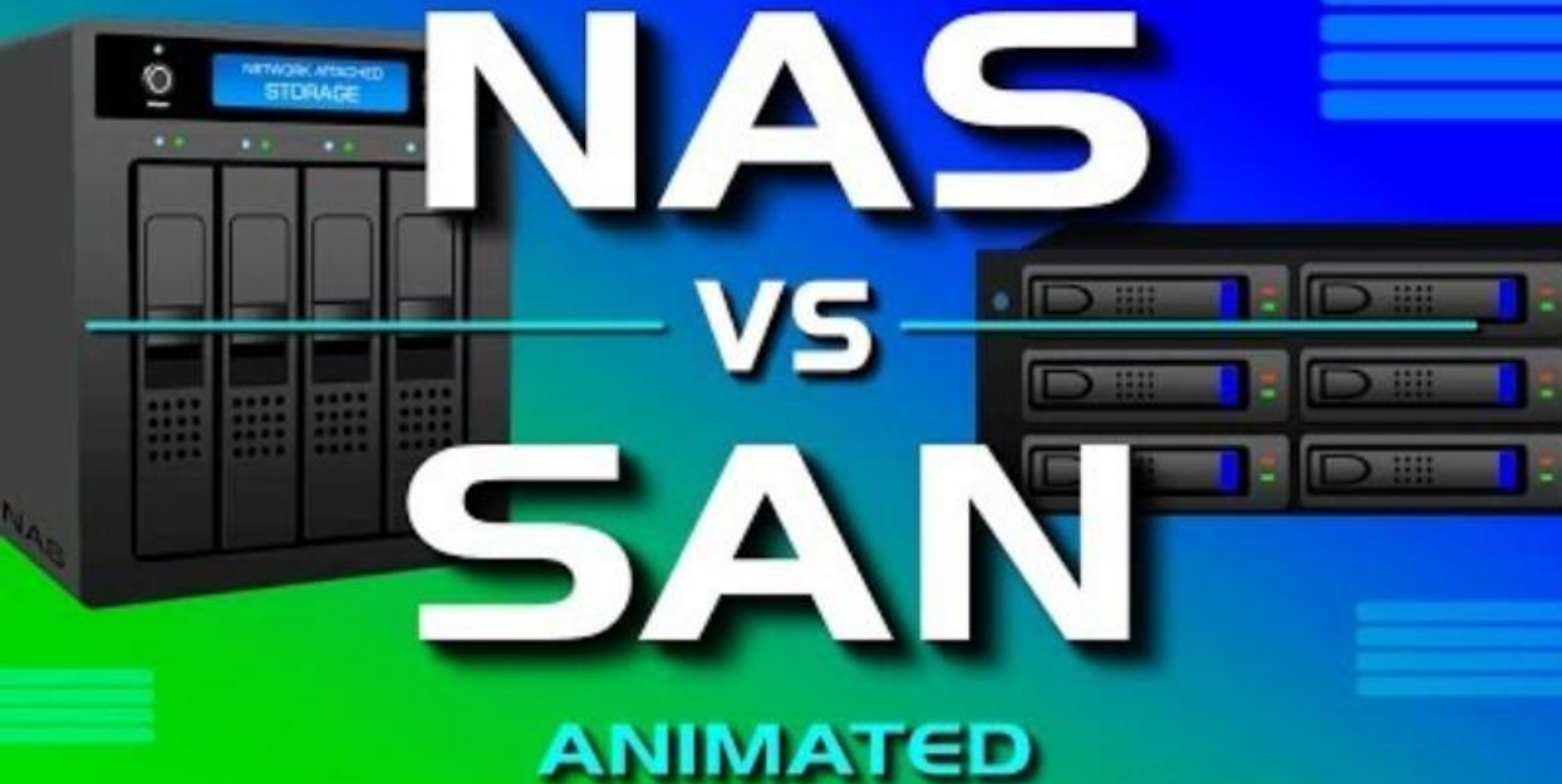


SAN

1. SAN (Storage Area Network)

- Alle componenten dubbel uitgevoerd
- Filesystem gemaakt door cliënt
- Connection: fibrechannel of iSCSI
- Installeren hypervisors of Databases (of virtuele NAS)
- Gekoppeld aan het netwerk
- Kan grote hoeveelheden data opslaan





Activiteit

- Bekijk de volgende video om het verschil tussen NAS en SAN te leren:

<https://youtu.be/3yZDDr0JKVc>

NAS vs SAN

NAS	SAN
Verschijnt als een sharemap in het computernetwerk.	Verschijnt als een extra schijf in de computernetwerk van de gebruiker.
De gebruiker kan deze niet formatteren of wijzigen naar ieder gewenste bestandstype.	Kan formatteren naar ieder gewenste bestandstype.
Je kan er alleen bestanden op zetten en delen	Op een SAN kunnen VM's maar ook een NAS worden geïnstalleerd.
Direct verbonden aan switch of router en direct benaderbaar via netwerk	Ondersteunt grote data-opslag met een snelle netwerkverbinding
Meestal gebruikt bij kleine bedrijven of woningen.	Is fout tolerant en data is verspreid over meerdere disks van verschillende servers
Goedkoper dan SAN	Hoge schaalbaarheid en redundantie
	SAN vormt in principe eigen netwerk en is niet direct onderdeel van LAN => minder gevoelig voor storingen.
	Duurder dan NAS en meestal toegepast bij grote bedrijven.

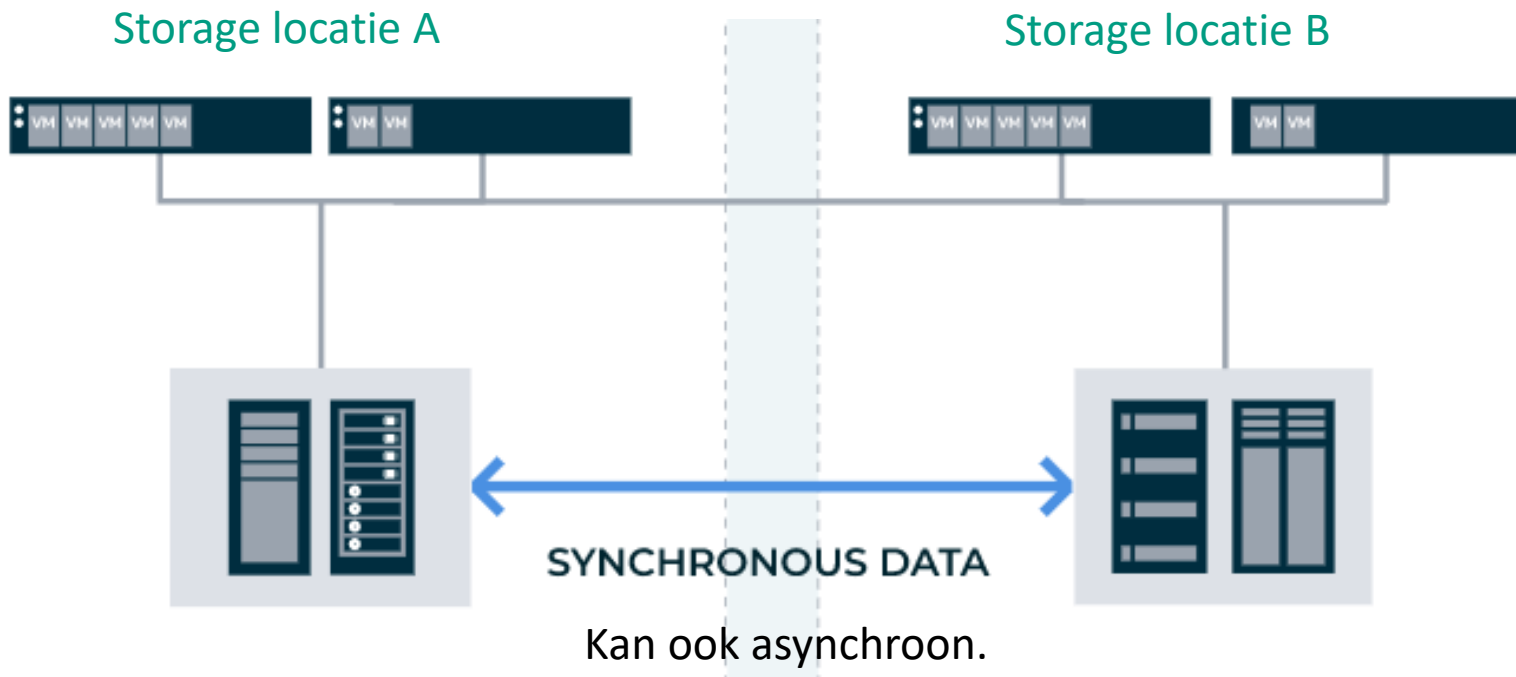
Clustering

Data nog beter beschermen: Data op meerdere locaties opslaan

- NAS of SAN b.v. dubbel uitvoeren
- Data kopiëren tussen beide sites

Synchroon:
Data op beide locaties exact gelijk

Asynchroon:
Data wordt steeds na vast
tijdinterval gekopieerd.
Bv elk uur.





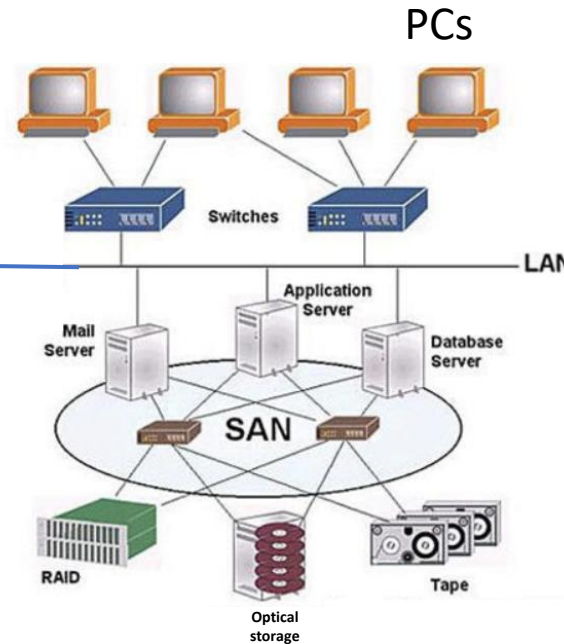
Activiteit

Storage Saxion

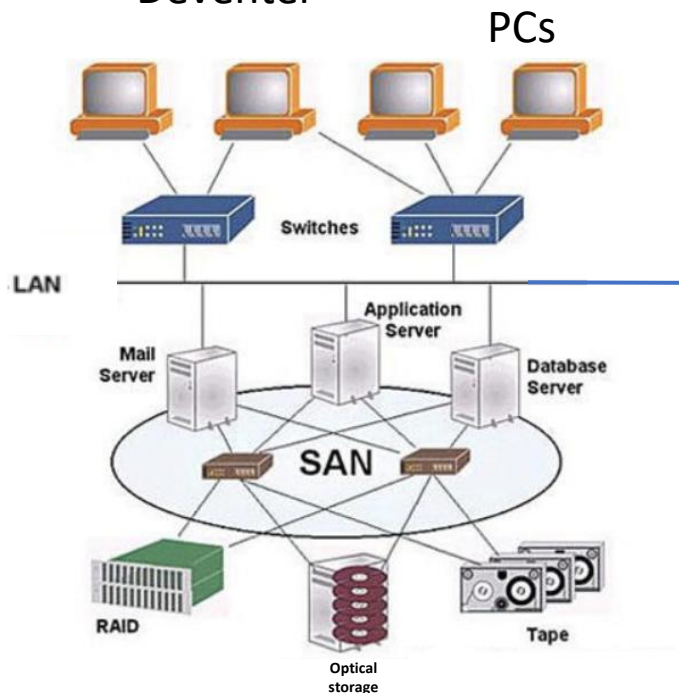
Ga ervan uit dat de Saxion Storage Architecture is zoals links weergegeven.

- Welke Single Points of Failure (SPOF's) zijn mogelijk opgelost en welke mogelijk overblijven?
- Moeten er nog back-ups gemaakt worden of zijn ze overbodig?

Saxion
Enschede



Saxion
Deventer



Gegevens tussen SAN
Enschede en SAN Deventer
worden synchroon
gerepliceerd.

ICT Security



Wat is security?

- Objecten **veilig houden**
- Objecten die **waardevol** zijn
- **Voorbeelden:**
 - **Auto:** beveiligd d.m.v. een slot en alarm
 - **Huis:** beveiligd d.m.v. een hek, slot en alarm

- Security is dus **per definitie preventief!**

Een schilderij dat al gestolen is kan immers niet meer beveiligd worden.



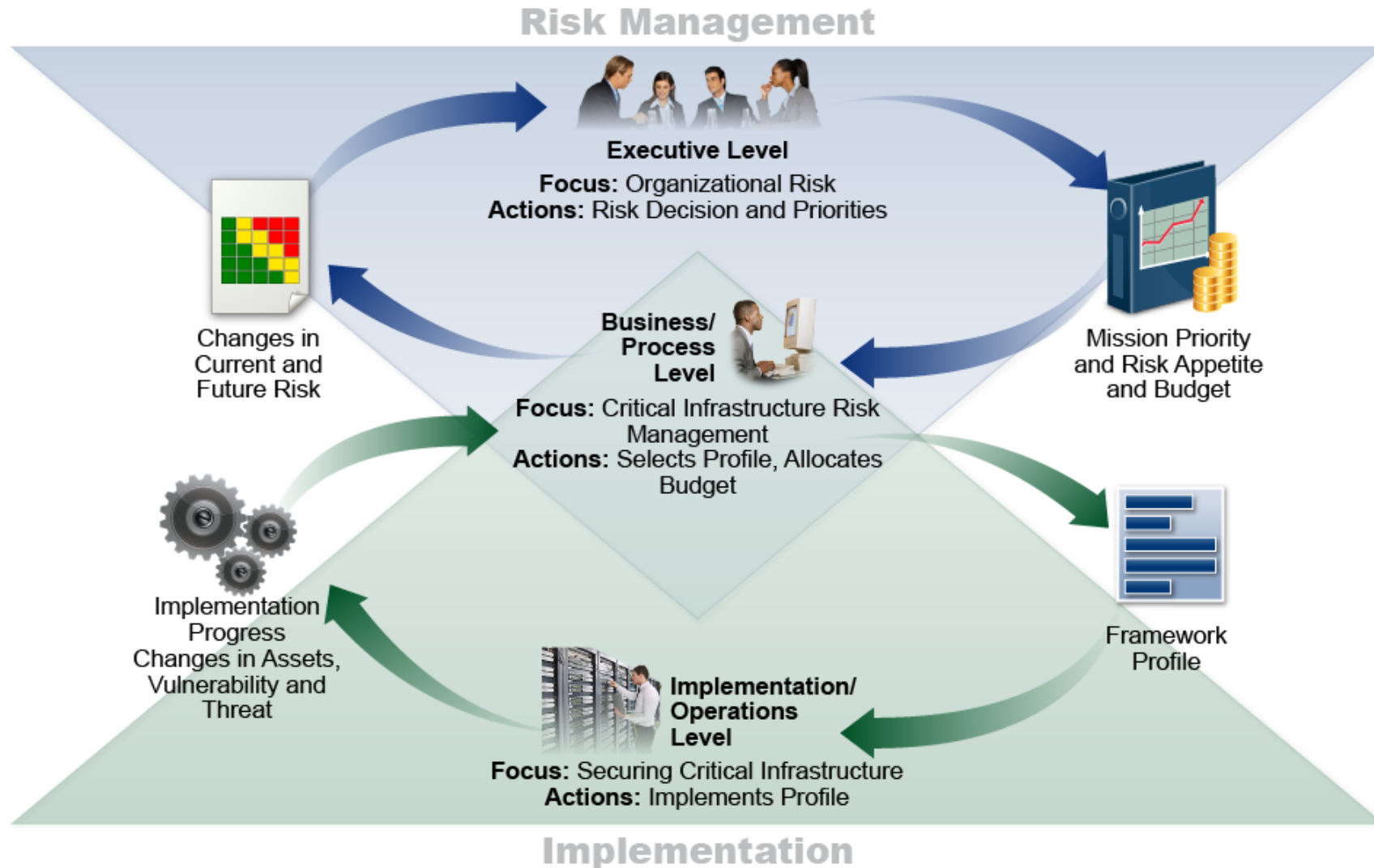
Security op ICT gebied

- Wat is het **waardevolle** dat op ICT gebied beveiligd moet worden ?

INFORMATIE / DATA !!

- **Kennis = macht**
- Denk bij ICT security bijvoorbeeld aan:
 - AVG wetgeving
 - Besturingssystemen
 - Bestandssystemen
 - Netwerken
 - Datadragers
 - Encryptie van bovenstaande

Bij een goede security aanpak is de hele organisatie betrokken!



CIA triad



Basisbegrip: de CIA triad

- Bij het beschermen van informatie moeten we de CIA triad toepassen.
- Ook wel **BIV classificatie** genoemd:
- **V**ertrouwelijkheid (**C**onfidentiality):
 - Wie mag waar bij? (Niet meer rechten dan nodig.)
- **I**ntegriteit (**I**ntegrity):
 - Is de informatie juist en volledig?
- **B**eschikbaarheid (**A**vailability):
 - Informatie moet beschikbaar zijn op het moment dat het nodig is, denk bijv. aan een calamiteitenplan i.v.m. een ransomware aanval



Basisbegrip: de CIA triad

- Om m.b.v. de CIA triad goede informatiebeveiliging op te zetten kunnen we dit verder uitwerken via een tweetal frameworks:
 - **ISO 27001/ 27002**
 - **NIST security framework**
- Dankzij deze frameworks kun je een gestructureerd security plan/systeem opzetten **zonder hierbij iets te vergeten!**



ISO 27001/ 27002



ISO 27001

- **ISO 27001** is een ISO standaard voor informatiebeveiliging.
- In Nederland vastgesteld als NEN norm **NEN-ISO/IEC 27001**.
- Internationale norm, kan van toepassing zijn op alle typen organisaties.
- **Voordelen:**
 - Specificeert eisen voor vaststellen
 - Implementeren
 - Uitvoeren
 - Controleren
 - Beoordelen
 - Bijhouden
 - Verbeteren van een Security Management Systeem voor informatiebeveiliging.
- **Nadelen**
 - Theoretisch opgezet waardoor praktisch wat lastiger te implementeren.
 - Met name geschikt voor bedrijven die ISO gecertificeerd willen zijn.

ISO 27002

- **ISO 27002 is een concretisering van ISO 27001** en geeft meer praktische richtlijnen over hoe security moet worden toegepast.
- Bestaat uit een lijst met maatregelen die een organisatie kan treffen waarmee je security risico's kunt beperken.
- Is wat **gedetailleerder** dan ISO 27001
- Toegang tot NEN info systeem: <https://connect.nen.nl/>
 - Klik op inloggen

*Log in through your
educational institution?*

Log in  →



Activiteit

- Bekijk het ISO 27002-gedeelte over *'enterprise requirements for access security'*.
- Noem 3 maatregelen om de toegang tot informatie te beperken!

Download ISO 27002 : Toegang tot het NEN-infosysteem:

<https://connect.nen.nl/>

Log in through your
educational institution?

Log in  →

NIST Cybersecurity Framework



NIST Cybersecurity Framework

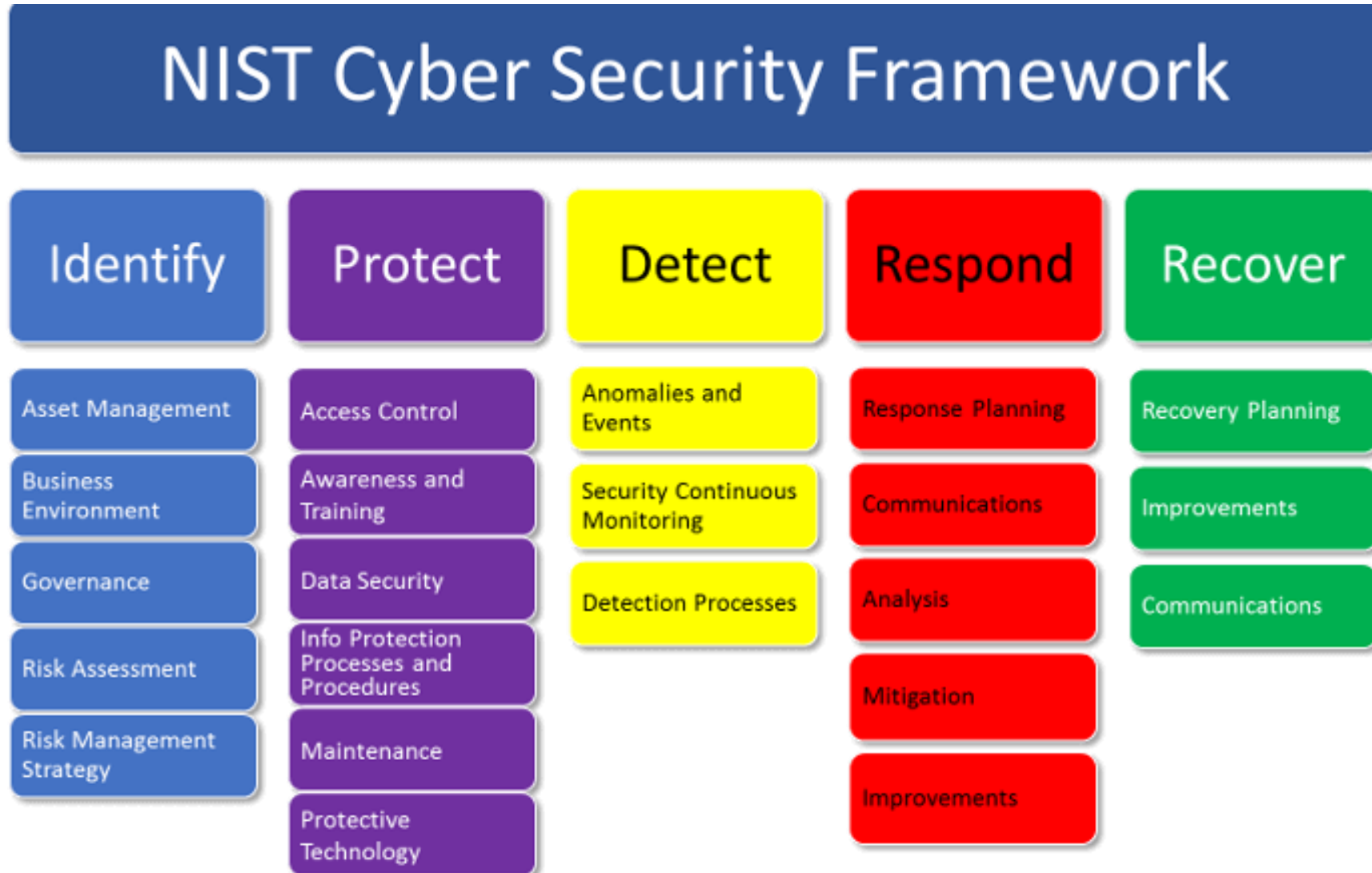
- **Internationaal** security framework, ontwikkeld door US National Institute of Standards en Technology.
- Technisch gedetailleerder, waardoor gemakkelijker te implementeren.
- Maakt een onderverdeling in 5 categorieën

Kan ook in de 'echte wereld' toegepast worden, bijvoorbeeld bij het beveiligen van een gebouw:

- **Identify:** Breng het gebouw eerst in kaart (ligging, grootte)
- **Protect:** Plaats een hekwerk en video camera's
- **Detect:** Zorg voor bewegingsdetectie op de camera's
- **Respond:** Schakel beveiligingsbedrijf in om ter plekke polshoogte te nemen
- **Recover:** Herstel het hekwerk als dit stuk gemaakt is bij de inbraak



NIST security framework (ICT)



IDENTIFY

“Develop the organizational understanding to manage cybersecurity risk to systems, assets, data, and capabilities.”

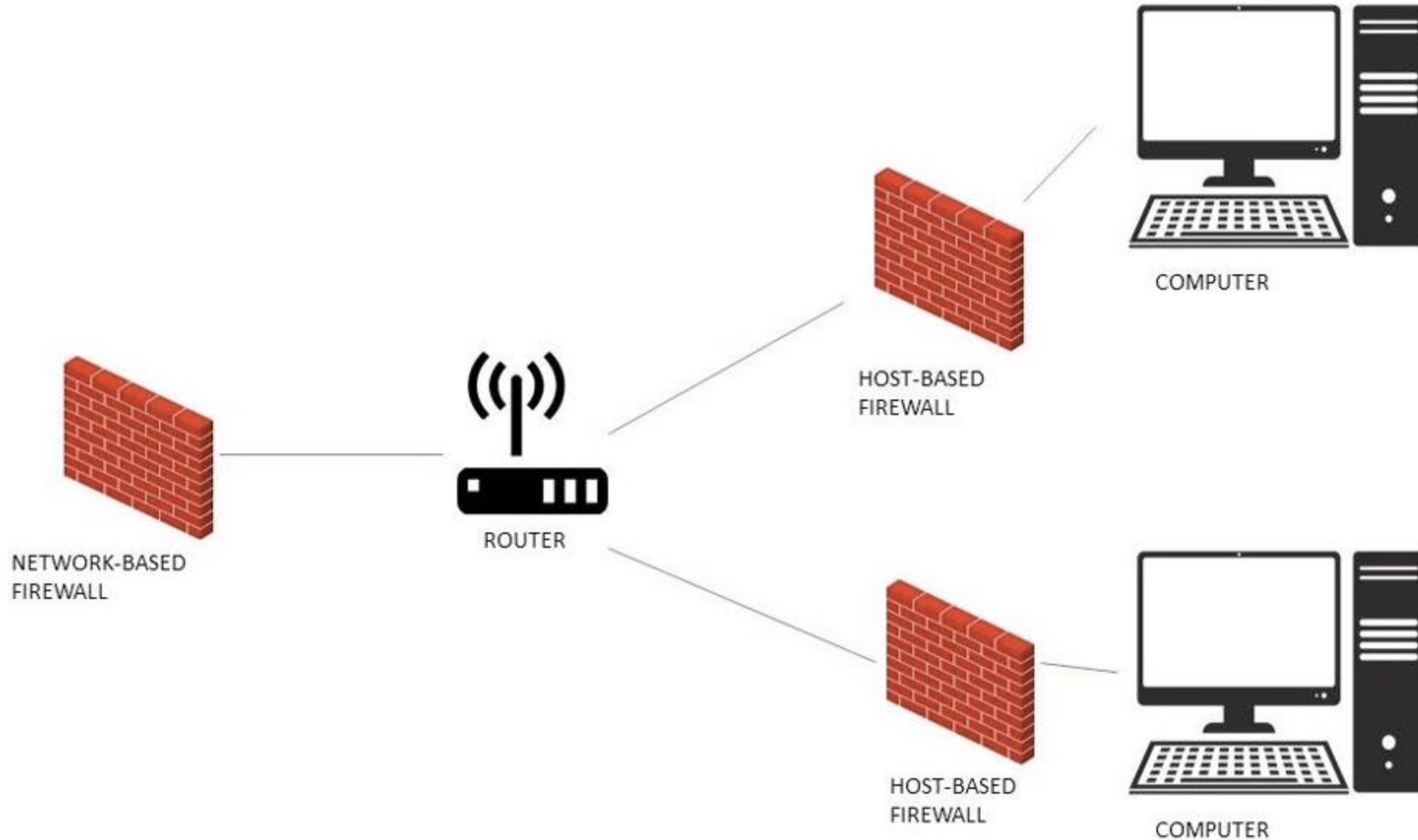
- **Denk hierbij bijv. aan:**
 - De business context, de resources die gebruikt worden voor kritische
 - Functionaliteit en de cybersecurity risico's die hieraan kleven.
 - Samengevat: breng de organisatie in kaart
- **Deliverables in deze categorie:**
 - Asset management (bijv. in Topdesk)
 - Business Environment (bijv. BPMN, Archimate)
 - Governance (beleid)
 - Risk assessment
 - Risk Management strategy

PROTECT

“Develop and implement the appropriate safeguards to ensure delivery of critical infrastructure services.”

- **First line of defence**, denk hierbij bijv. aan:
 - Authenticatie, autorisatie en accounting, AAA (wachtwoordbeleid, account lock-out, RBAC, filesysteemrechten etc.)
 - Firewalls (infra en host)
 - Fysieke toegang tot serverruimte
 - Fysieke toegang tot switchpoorten in het gebouw (NAC)
 - WiFi
 - Encryptie
 - Bewustwording gebruikers! (phishing, ransomware)

Protect: using firewalls



Source: <https://nl.pinterest.com/pin/864480090974147011/>

Detect

“Develop and implement the appropriate activities to identify the occurrence of a cybersecurity event”

Het detecteren van inbraken en aanvallen op de infra, denk hierbij aan het inrichten van:

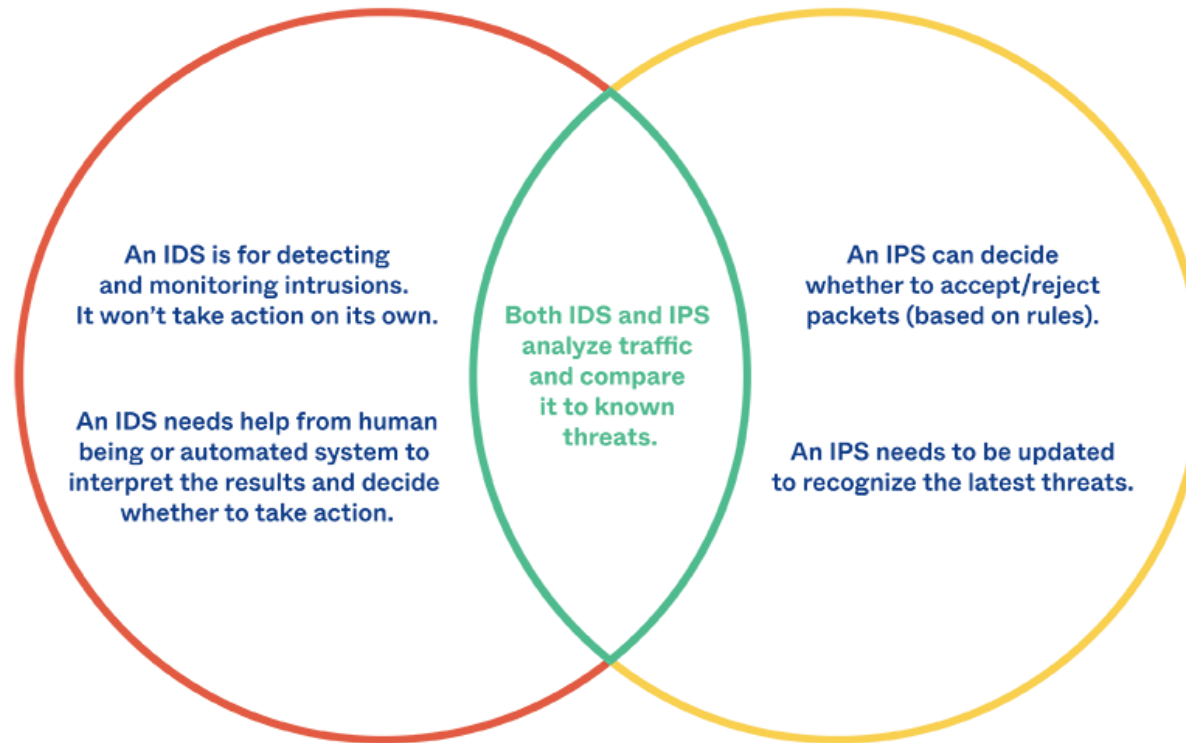
- AntiVirusscanner: Centraal te managen, heuristisch etc.
- Intrusion Detection System (IDS)
- Intrusion Prevention System (IPS)
- Security information and event management (SIEM)
- Honeypot
- Bewustwording gebruikers (verdachte activiteiten)

Deliverables in deze categorie:

- Anomalies and Events
- Security Continuous monitoring
- Detection Processes

IDS vs IPS

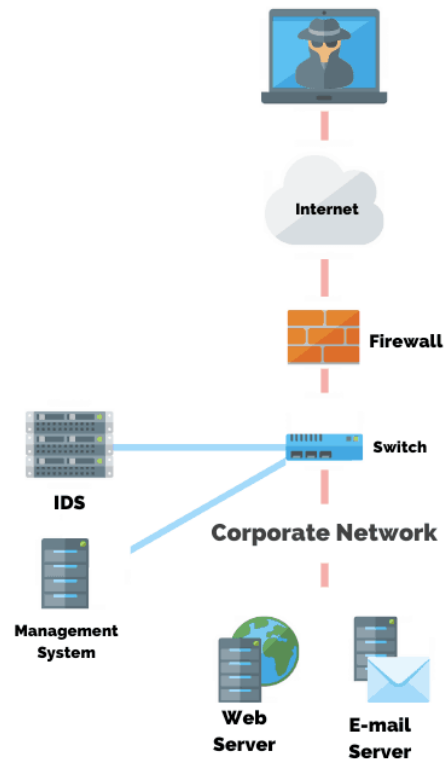
IDS vs IPS



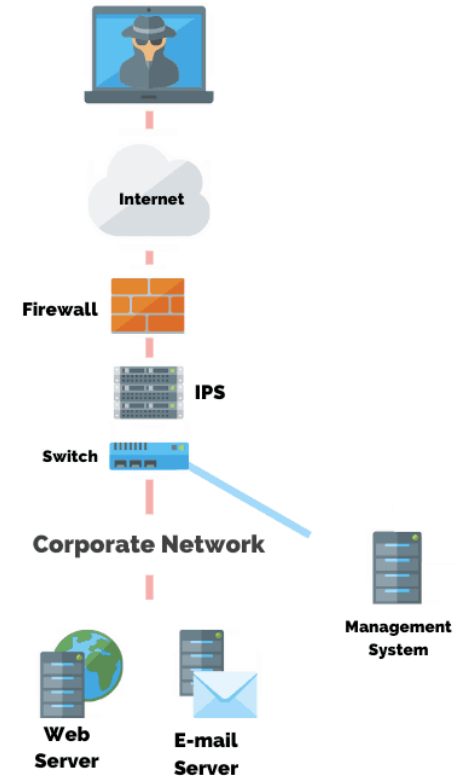
okta

IDS alleen monitoring, IPS kan ingrijpen in netwerk

Intrusion Detection System (IDS)



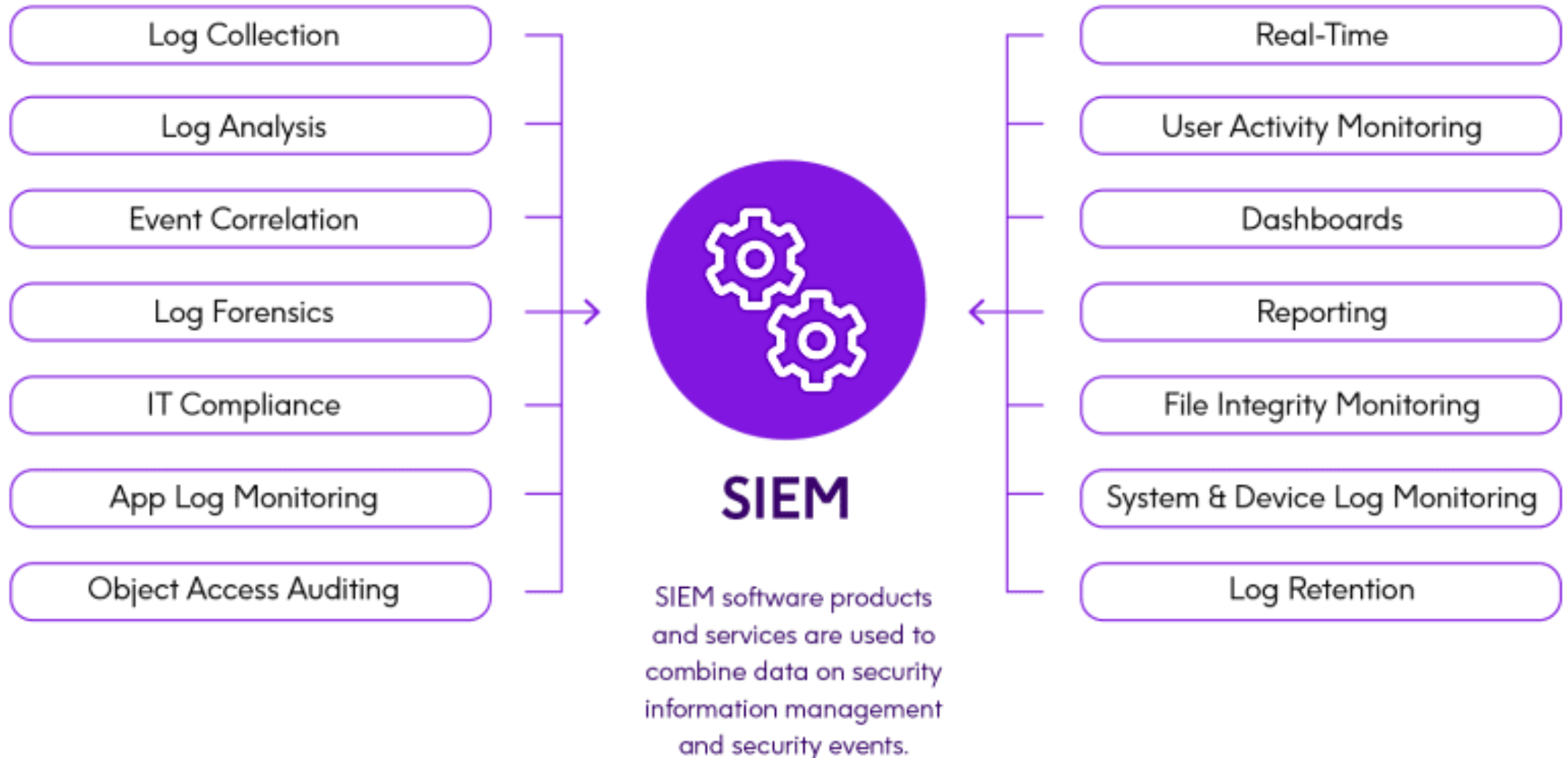
Intrusion Prevention System (IPS)



VS

Bron: <https://purplesec.us/intrusion-detection-vs-intrusion-prevention-systems/>

IPS, IDS also known as SIEM



Respond

“Develop and implement the appropriate activities to take action regarding a detected cybersecurity event”

Probeer de impact van security issues zoveel mogelijk te beperken:

- Tijdelijk uitschakelen firewalls, servers en eventueel ander infracomponenten
- Doorvoeren van tijdelijke maatregelen (mitigation)
- Communiceer zoveel mogelijk met security stakeholders (inrichten war-room)
- Monitor de activiteiten

Deliverables in deze categorie:

- Response planning (draaiboeken)
- Communications
- Analysis
- Mitigation and improvements

Recover

“Develop and implement the appropriate activities to maintain plans for resilience and to restore any capabilities or services that were impaired due to a cybersecurity event.”

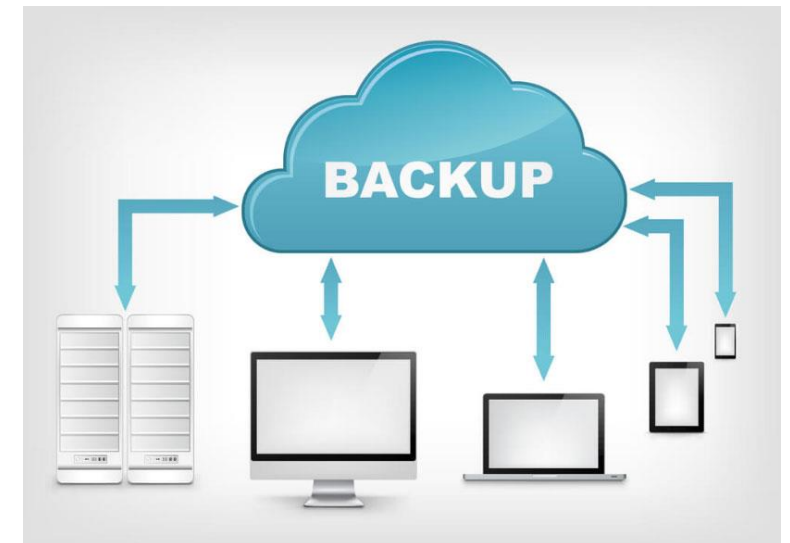
De schade die veroorzaakt is moet hersteld worden. (Denk aan gewiste of ge-encrypte data.)

Betalen voor un-encrypten word altijd afgeraden!

- Back-up systeem is hierbij het belangrijkste (RPO, RTO, offsite, op andere infrastructuur, ge-encrypt)
- Disaster recovery
- Communiceer bovenstaande met de organisatie

Deliverables in deze categorie:

- Recovery planning
- Improvements
- Communications





Activiteit

In januari 2025 werden de systemen van de Technische Universiteit Eindhoven gehackt.

- Lees het artikel en het managementrapport over de hack. [Klik hier](#).
- Welke oorzaak of oorzaken vind je in het document dat de hack heeft veroorzaakt??
- Welke maatregelen had de universiteit kunnen/moeten nemen om dit te voorkomen?

Werken aan de casus





Casus

- Doe de opdrachten van de week 5

Raadpleeg het opdrachtdocument en het sjabloonrapport voor meer details.

Any questions?

